

Software Bill of Materials (SBOM) & Dependency Governance Justification

Document Reference: DOC-11

System: Case Ace v2.0 Client Consultation Recording & Note Drafting System

Organisation: Citizens Advice Wandsworth (CAW)

Standard: ISO/IEC 27001:2022 A.8.30 (Supply Chain) & Executive Order 14028

SBOM Format: CycloneDX 1.5 JSON (evidence/sbom.json)

Status: Formally Verified & Pinned Baseline

Classification: Official-Sensitive / Governance Pack

1. Supply Chain Security Architecture & Principles

Handling confidential advice consultations and Special Category Data under UK GDPR Article 9 requires the strictest software supply chain controls. Every runtime dependency introduces potential attack vectors (dependency confusion, malicious code injection, data exfiltration, automated telemetry).

Core Supply Chain Invariants:

Absolute Version Pinning: All dependencies in both client/package.json and backend/package.json are pinned to exact semantic versions (no caret ^, tilde ~, or open ranges).

Cryptographic Integrity Verification: package-lock.json records SHA-512 cryptographic sub-resource hashes for all downloaded tarballs.

Zero Automated Telemetry Policy: Every client dependency is statically and dynamically audited to ensure zero phone-home behavior, analytics beacons, or background network calls.

Permissive Open Source Licensing Only: Permitted licenses are restricted to MIT, Apache-2.0, BSD-3-Clause, and ISC. Copyleft / viral licenses (GPL, AGPL) are prohibited.

Continuous Vulnerability Scanning: Zero High or Critical CVEs in production dependency trees.

2. Production Runtime Component Justification

3. Disallowed & Rejected Component Register

The following categories of libraries were evaluated and strictly rejected to safeguard client privacy:

Third-Party Analytics & Telemetry (Google Analytics, Mixpanel, Segment, PostHog):

REJECTED. Violates Zero-Telemetry Policy and UK GDPR data minimisation.

Client-Side Error Trackers (Sentry, LogRocket, Bugsnag, Datadog RUM):

REJECTED. Crash reporters capture memory dumps, console logs, and DOM snapshots which could leak unredacted client financial and health disclosures to third-party cloud servers.

External CDN Asset Loaders (Google Fonts, Cloudflare cdnjs, unpkg):

REJECTED. All fonts, scripts, and WASM binaries are self-hosted and bundled locally to uphold Content Security Policy (default-src 'none').

Non-Volatile Storage Wrappers (redux-persist, localforage, idb-keyval):

REJECTED. Violates Constraint C1 (Zero Non-Volatile Persistence).

4. Software Bill of Materials (CycloneDX 1.5)

The complete machine-readable SBOM is maintained in evidence/sbom.json. It contains:

Complete purl (Package URL) identifiers for all 18 direct and transitive runtime packages.

Declared SPDX license identifiers.

Pinned package versions and dependency graph relationships.